Cyber Risk Intelligence & Security Posture (CRISP): From Compliance to Threat-Informed Intelligence

Author: Eric Kaden, eric.kaden@icloud.com
Advisor: Lee Crognale

Accepted: February 15, 2026

Abstract

Large organizations conducting Security Technical Implementation Guide (STIG) assessments generate massive volumes of compliance data, often exceeding 300,000 findings per assessment cycle. Traditional analysis approaches prioritize findings by severity category, producing compliance metrics that satisfy audit requirements but fail to inform threat-aligned defensive strategies. Security teams can identify misconfigurations but struggle to articulate what those gaps mean for adversary risk.

This paper presents CRISP (Cyber Risk Intelligence & Security Posture), a platform that automates the transformation of STIG compliance data into threat-informed security intelligence. CRISP ingests raw assessment files, maps findings to NIST SP 800-53 controls and MITRE ATT&CK techniques, compares the resulting exposure profile against over 140 documented Advanced Persistent Threat groups, and presents results through multi-level visualizations for executives, security operations leads, and analysts. Additional capabilities include attack path simulation with mitigation modeling, temporal trend tracking, and an LLM-powered assistant for natural language interpretation.

Performance benchmarks demonstrate that the platform processes over 300,000 findings in under five minutes, achieving a 99.94% data reduction to fewer than 200 unique ATT&CK techniques. Qualitative evaluation confirms that outputs meet criteria for clarity, actionability, and communicative value across organizational personas. CRISP demonstrates that properly transformed compliance data constitutes threat intelligence, enabling organizations to leverage mandatory assessment activities for strategic defense.

1. Introduction

Every large enterprise conducting Security Technical Implementation Guide (STIG) assessments faces a persistent disconnect between compliance measurement and threat-informed defense. Assessment tools can identify thousands of configuration deviations across an enterprise, but the resulting data is organized around audit categories rather than adversary behavior. Security teams inherit findings sorted by severity rather than by operational relevance, leaving a critical question unanswered: which misconfigurations matter most to the threat actors targeting their environment?

This research originated from an operational observation at the U.S. Army Cyber Protection Brigade during a 2023 deployment. An analyst supporting Command Cyber Readiness Inspections described the core frustration: after days of manually processing STIG assessment files, he could report what was broken but not what it meant for adversary risk. The compliance data, threat frameworks, and control mappings all existed independently, but no tool connected them into a unified analytical workflow. That gap motivated the development of CRISP (Cyber Risk Intelligence and Security Posture), the platform presented in this paper.

1.1 The Broader Problem Context

The challenge my colleague faced was not unique. Any large organization that relies on STIG assessments encounters the same fundamental problem: the sheer volume of data overwhelms the capacity for meaningful analysis. The DISA STIG library comprises hundreds of individual guides, each containing dozens to hundreds of configuration checks per host (DISA, 2025). Across an enterprise environment spanning multiple technology areas, a single assessment cycle routinely generates hundreds of thousands of individual findings; the assessment analyzed in this research produced 312,327. Processing this volume manually can consume days of dedicated analyst effort per assessment cycle.

The traditional approach relies almost exclusively on severity categories. DISA classifies each finding as CAT I (high), CAT II (medium), or CAT III (low) based on potential impact. Security teams sort by category, address CAT I first, and work down the

list. This method is simple and widely understood, but it is fundamentally compliance-oriented rather than threat-oriented. It answers, “what is broken?” without addressing the more operationally relevant question: “what does this mean for an adversary?”

Severity categories do not indicate which misconfigurations map to techniques that real-world threat actors actually use. They do not reveal whether a finding enables initial access, lateral movement, or persistence. Existing tools address pieces of this problem, but none provide an integrated solution. Vulnerability scanners export compliance findings but do not map them to adversary behavior frameworks. SIEM platforms correlate log data with MITRE ATT&CK but operate on detection data rather than compliance assessments. Researchers have identified this disconnect as a systemic gap, noting that few existing tools provide countermeasures by linking attack and defense frameworks together (Kwon et al., 2020). Compliance data and threat intelligence remain in separate silos, and bridging this gap manually requires mapping STIG findings to NIST SP 800-53 controls, then mapping those controls to ATT&CK techniques, then comparing the resulting profile against known adversary groups. The process is error-prone, difficult to reproduce, and nearly impossible to scale.

1.2 Purpose, Scope, and Contribution

This research has four primary objectives. First, it demonstrates the implementation of CRISP as a novel synthesis of existing techniques, integrating STIG parsing, NIST 800-53 mapping, MITRE ATT&CK visualization, APT overlap analysis, and LLM-assisted interpretation into a single, cohesive platform. Second, it evaluates the system through qualitative analysis of its outputs, assessing clarity, actionability, and communicative value. Third, it shows practical impact across multiple organizational personas, including executives who need strategic intelligence, security operations leads who need prioritization guidance, and analysts who need efficient workflows. Fourth, it establishes a foundation for future research in compliance-to-threat translation.

The primary contribution is novel integration. While individual components exist independently, no existing platform chains them together into a unified, automated pipeline. A recent systematic review covering 417 peer-reviewed publications found that vulnerability management and cyber threat intelligence rank among the most common

operational applications of the ATT&CK framework (Jiang et al., 2025). However, most implementations address only portions of the compliance-to-threat translation problem. CRISP extends this body of work by automating the entire workflow from raw audit data to strategic intelligence, applying automation principles that prior research has shown can reduce processing time from hours to minutes while maintaining accuracy comparable to that of human experts (Zhang et al., 2020).

This paper argues that an integrated platform automating the end-to-end transformation of STIG compliance data into threat-informed security posture can dramatically reduce analysis time while producing actionable, executive-ready intelligence. By combining automated mapping, interactive visualizations, adversary overlap analysis, attack path simulation, and AI-assisted interpretation, such a platform aligns defensive efforts with real-world adversary behavior. The result transforms compliance from a checkbox exercise into a strategic cybersecurity capability.

2. Research Method

2.1 Implementation-Based Research Approach

This study employs an implementation-based research methodology, where the primary contribution is the design, development, and deployment of a functional system rather than a controlled experimental comparison. Such an approach is appropriate when the research question centers on feasibility and practical utility: can a platform that automates the STIG-to-ATT&CK workflow be built, and does it produce outputs that serve real operational needs?

The underlying mappings between NIST SP 800-53 controls and MITRE ATT&CK techniques already exist and have been validated by authoritative sources (MITRE Corporation, 2022). The research question is whether a production-ready platform can operationalize these mappings at scale. This approach aligns with the design science paradigm, in which knowledge of a problem domain is achieved through the building and evaluation of designed artifacts (Hevner et al., 2004), a tradition well established in applied cybersecurity research.

2.2 System Design and Requirements

The design targeted large organizations with geographically distributed operations and complex compliance requirements. The target environment includes federal agencies, defense contractors, and enterprises that conduct regular STIG assessments across multiple sites. The design process identified three primary user personas: executives (typically CISOs) who require strategic views without granular technical detail; security operations leads who require attack path analysis and prioritization guidance; and security analysts who require speed, automation, and export capabilities. From these personas, five core requirements emerged: scalability to handle hundreds of thousands of findings, speed measured in minutes rather than days, threat alignment framing outputs in adversary behavior language, multi-tenancy supporting multiple sites with appropriate access controls, and visualization accessible to both technical and non-technical audiences.

2.3 Development Process

Development proceeded in four phases. Phase I built the core ingestion and analysis engine. The system accepts STIG compliance results in CSV format from any scanner, filters to open findings, extracts NIST SP 800-53 Revision 4 control references, and maps these controls to MITRE ATT&CK techniques using a pre-validated reference file containing 4,694 control-to-technique associations derived from collaborative research between NIST and MITRE. The engine applies severity weighting (Low = 1, Medium = 4, High = 10), scaling nonlinearly to reflect the disproportionate operational risk posed by higher-severity findings. It then aggregates technique frequencies and compares the resulting technique set against over 140 documented adversary groups from the MITRE ATT&CK knowledge base, producing a ranked list of threat actors whose tactics most closely align with the organization's exposure profile.

Phase II extended the core engine into an enterprise-ready platform with a hierarchical data model in which organizations contain sites and sites contain analysis runs. PostgreSQL provides the database backend with row-level security, ensuring organizational isolation. Role-based access control supports Admin, Analyst, and Viewer

permission levels. The platform uses passwordless authentication. The architecture supports 10 to 20 concurrent analysis runs and over 100 simultaneous user sessions.

Phase III built the interactive frontend using Next.js and React with dedicated libraries for data visualization, geographic mapping, and graph-based interaction. Key interfaces include an organization dashboard with high-level key performance indicators (KPIs), a geographic map view displaying site locations, an embedded ATT&CK Navigator rendering technique prevalence as an interactive heatmap, temporal trend charts, and an attack path simulator that visualizes plausible attack progressions and supports mitigation modeling with real-time risk score updates. Export capabilities include ATT&CK Navigator JSON, CSV reports, and XLSX workbooks.

Phase IV added natural language interaction through an LLM-driven chat assistant powered by an open-source large language model, served through a low-latency inference API optimized for response times under 500 milliseconds. The assistant receives full analysis context and answers queries in plain language. This integration reflects broader trends in applying retrieval-augmented generation to domain-specific analytical tasks (Lewis et al., 2020), grounding LLM responses in organizational data rather than relying solely on pre-trained knowledge.

3. Findings and Discussion

CRISP's value is best understood through the operational challenges it addresses. The findings below are organized around six core problems, from scale to communication, followed by additional platform capabilities, a multi-persona walkthrough demonstrating practical utility, and a qualitative assessment against the criteria of clarity, actionability, and communicative value.

3.1 Core Platform Capabilities and Performance

3.1.1 Addressing the Scale Challenge: Automated Analysis Pipeline

The most immediate barrier to effective STIG analysis is volume. A single assessment can generate between 50,000 and 300,000 or more individual findings. When analysts manually approach this data, even basic filtering and sorting can consume hours.

Extracting meaningful patterns and producing reports suitable for leadership can extend the process to multiple days.

CRISP eliminates this bottleneck through automated ingestion and processing. The platform accepts CSV exports from any STIG scanning tool, parses the required fields, filters to open findings, extracts NIST control references, executes the mapping pipeline, and generates complete results without manual intervention. The entire workflow runs in the background, freeing analysts to focus on interpretation rather than data wrangling.

Performance benchmarks demonstrate the platform's capability at scale. Using a reference dataset of 312,327 STIG findings distributed across 10 technology areas, CRISP completed full processing in 4 minutes and 37 seconds. The output condensed the raw findings into 187 unique ATT&CK techniques, resulting in a data reduction ratio of 99.94 percent (Figure 1). Work that previously required dedicated days of spreadsheet manipulation now completes during a coffee break.

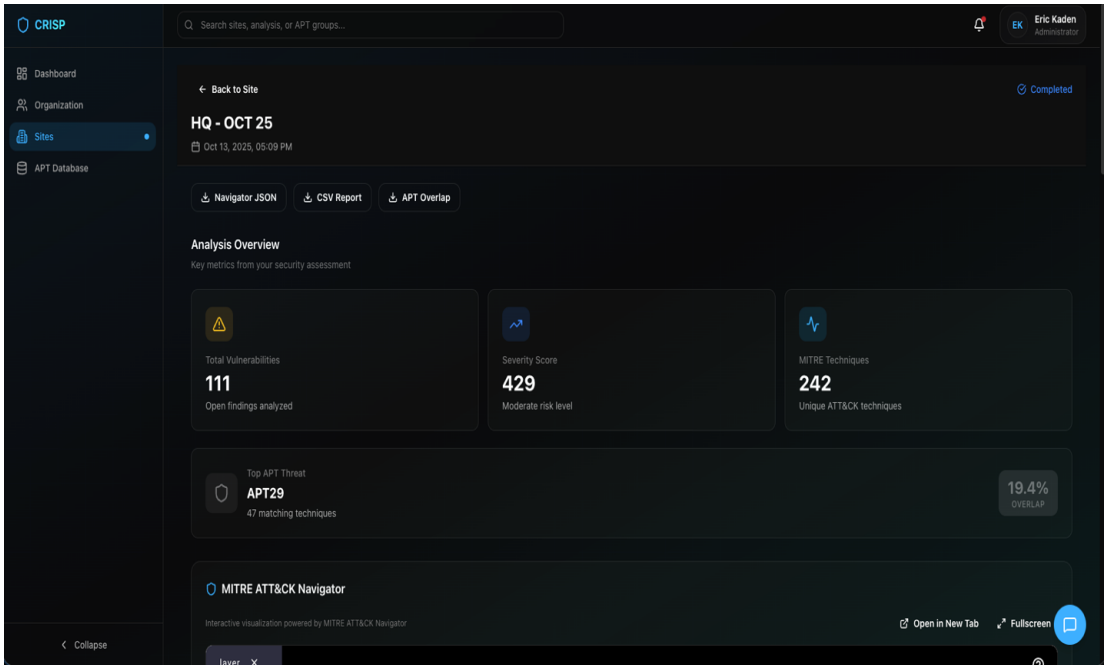


Figure 1: Analysis Overview Displaying Processing Metrics for a Completed Run, Including Total Vulnerabilities, Severity Score, Technique Count, and APT Overlap

3.1.2 Addressing the Prioritization Challenge: APT Overlap Analysis

Eric Kaden, eric.kaden@icloud.com

Knowing that an organization has thousands of open findings is not the same as knowing which findings matter most. Traditional prioritization relies on severity categories or CVSS scores, but these metrics reflect potential impact in isolation. They do not account for whether a misconfiguration aligns with techniques that active threat actors employ. Prior research confirms that traditional severity metrics correlate poorly with real-world exploitation, and that incorporating threat intelligence into prioritization yields measurably better remediation outcomes (Jacobs et al., 2021). A CAT I finding that maps to a technique no known adversary uses may be less urgent than a CAT II finding enabling a tactic favored by nation-state groups targeting the organization's sector.

CRISP addresses this gap through automated APT overlap analysis. After mapping STIG findings to ATT&CK techniques, the platform compares the resulting technique set against over 140 Advanced Persistent Threat groups cataloged in the MITRE ATT&CK knowledge base. For each group, CRISP calculates an overlap percentage, representing the proportion of that adversary's known techniques that correspond to open findings. The platform ranks groups by overlap, surfacing threat actors whose operational playbooks most closely match the organization's current exposure.

This approach reframes prioritization around adversary relevance. Rather than asking "which findings are most severe?" the platform enables analysts to ask, "which findings would matter most to the adversaries likely to target us?" The ranking is exportable as CSV for integration with other tools and workflows (Figure 2).

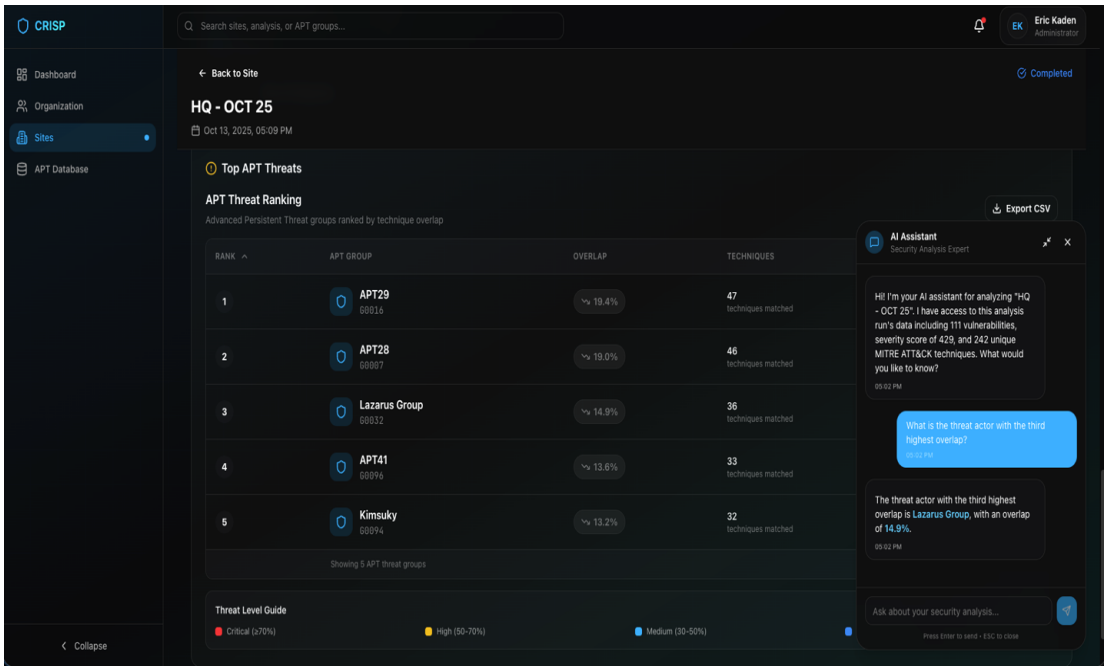


Figure 2: APT Threat Ranking Displaying Top Threat Actors by Overlap Percentage. APT29 Ranks Highest with 47 Matching Techniques and 19.4% Overlap

3.1.3 Addressing the Visualization Challenge: Multi-Level Dashboards

Raw data and ranked lists serve analysts well, but executives and strategic planners require different presentations. A CISO preparing for a board meeting cannot present a spreadsheet of 187 ATT&CK techniques. A regional security director overseeing multiple facilities needs a geographic context that a table cannot provide. Effective security communication requires visualizations tailored to the audience and purpose.

CRISP provides three complementary visualization layers designed for different organizational levels. The Organization Dashboard presents enterprise-wide KPIs at a glance, displaying total sites under management, active analyses, aggregate severity scores, and APT groups with significant technique overlap. Trend indicators show month-over-month changes, enabling executives to assess whether organizational posture is improving or degrading quickly. This dashboard (Figure 3) answers the executive question: “How are we doing overall?”

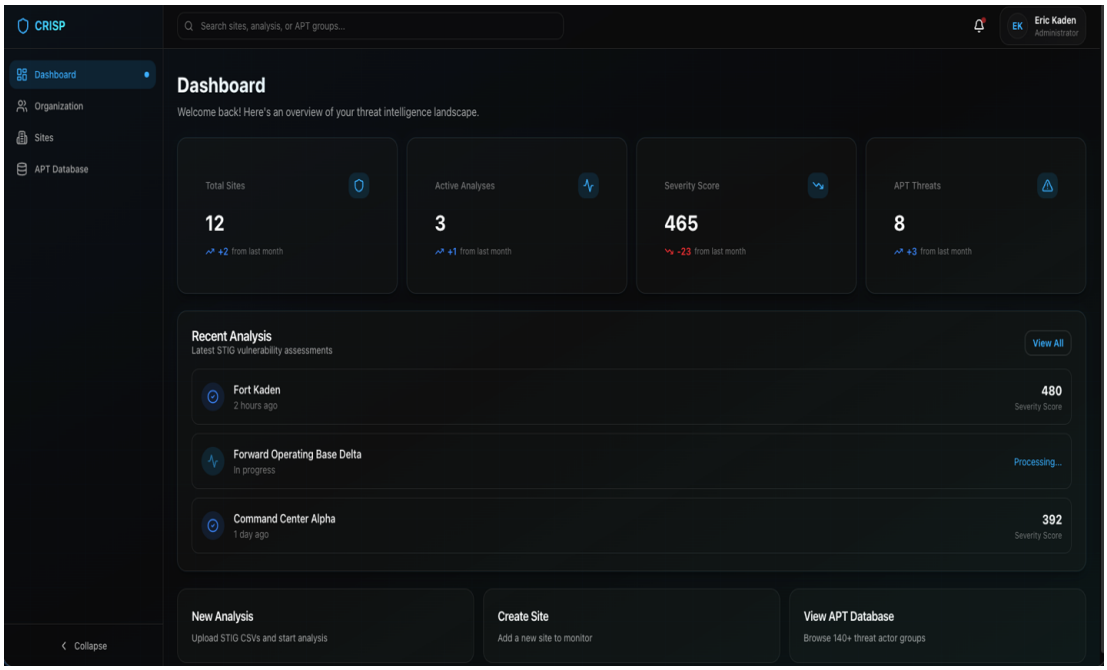


Figure 3: Organization Dashboard with Enterprise-Wide KPIs, Trend Indicators, and Recent Analysis Activity Timeline

The Geographic Map View renders all organizational sites on an interactive map with color-coded markers indicating analysis status. Clicking a marker reveals site details, including location, classification level, and completed analysis runs. For organizations with distributed operations, this view provides immediate spatial awareness of where risk concentrates. A cluster of red markers in one region might indicate systemic issues requiring coordinated remediation. This visualization (Figure 4) answers the strategic question: “Where are our problems?”

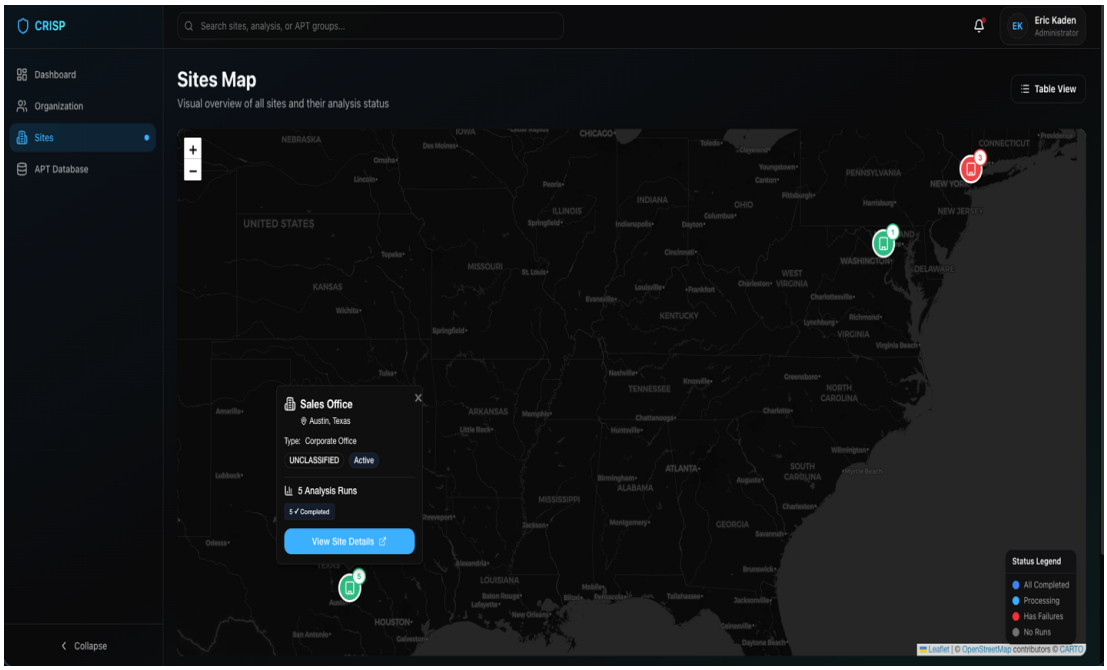


Figure 4: Geographic Map View with Color-Coded Site Markers and Detail Pop-up Showing Site Metadata

The MITRE ATT&CK Navigator integration renders technique prevalence as an interactive heatmap organized by tactic category. Techniques with higher finding counts appear in warmer colors, drawing attention to the areas of most significant exposure. The Navigator follows the standard ATT&CK matrix layout, which has become a foundation for threat modeling across government, academia, and industry (Al-Sada et al., 2024). Users can export the layer as JSON for use in other ATT&CK-compatible tools. This view (Figure 5) answers the technical question: “What can adversaries do to us?” Together, these three layers serve audiences from the boardroom to the operations center without requiring separate tools.

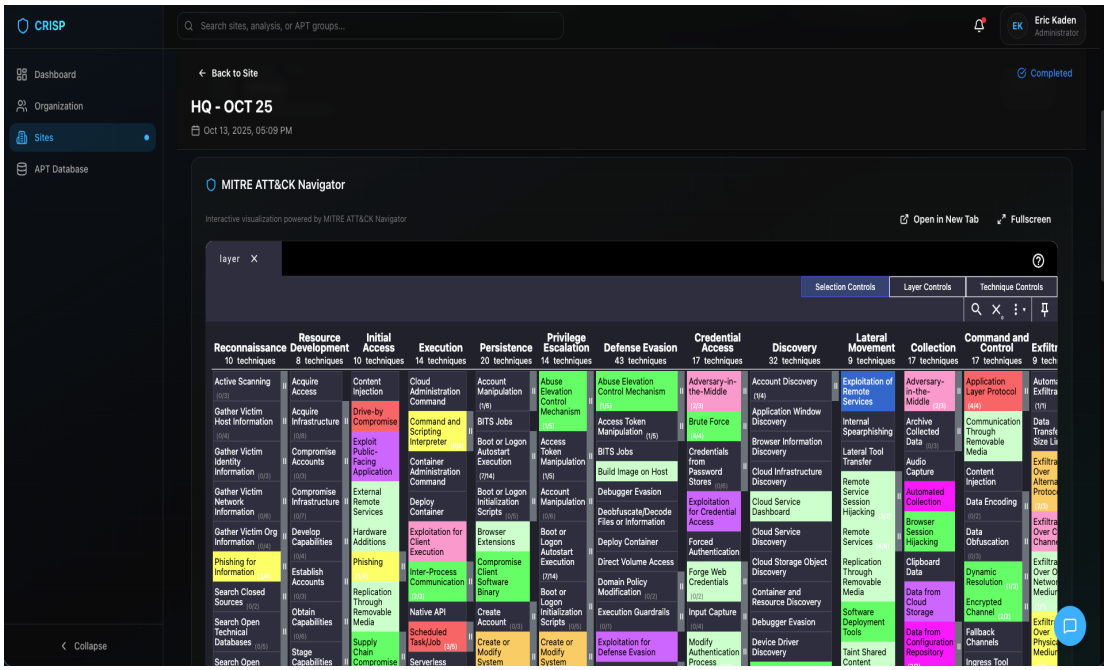


Figure 5: ATT&CK Navigator Heatmap Displaying Technique Coverage Across Tactic Categories

3.1.4 Addressing the Planning Challenge: Attack Path Simulation

Knowing which techniques affect an organization does not automatically reveal how an adversary might chain them together. Individual findings exist in isolation, but adversaries operate in sequences: initial access enables execution, execution enables persistence, persistence enables lateral movement. Attack path modeling and kill-chain mapping represent an emerging application of the ATT&CK framework for operational defense planning (Jiang et al., 2025).

CRISP addresses this through an interactive Attack Path Simulator that visualizes plausible attack progressions based on discovered vulnerabilities. The simulator constructs paths through the MITRE ATT&CK kill chain, linking techniques from the organization's exposure profile into coherent attack narratives. The simulator ranks multiple scenarios by probability. In Figure 6, the most probable path progresses from Valid Accounts (T1078) through Command and Scripting Interpreter (T1059) to Scheduled Task/Job (T1053), reaching Exploitation for Privilege Escalation (T1068) with a cumulative attack probability of 69.1%.

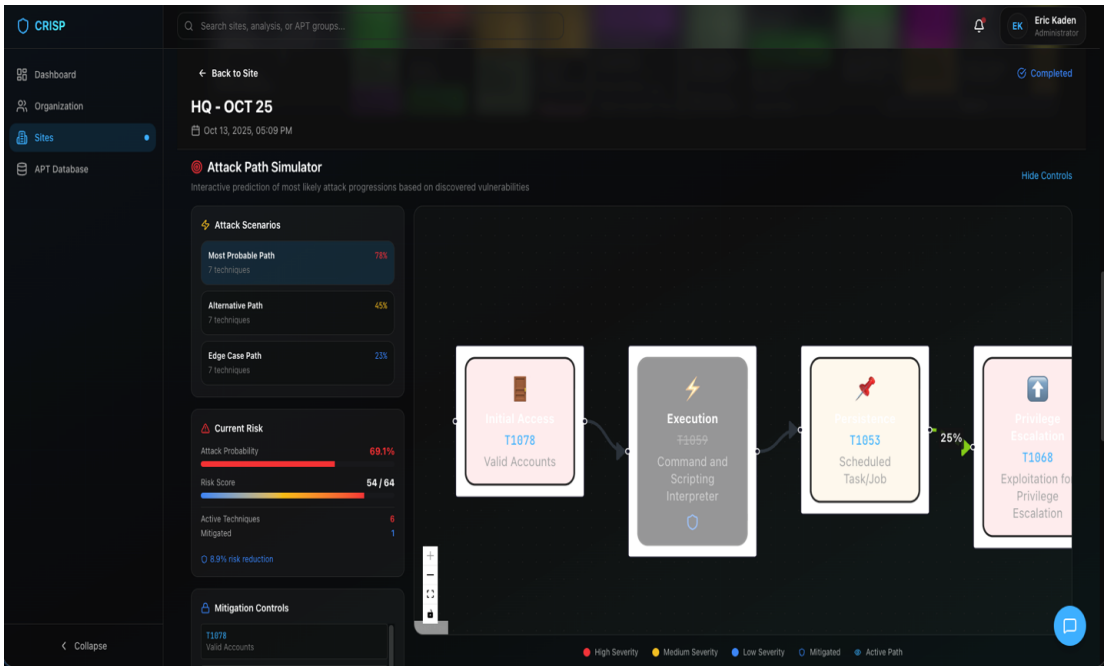


Figure 6: Attack Path Simulator Displaying Attack Scenarios with Technique Chains, Probability Calculations, and Mitigation Controls

The simulator supports mitigation modeling: users can mark techniques as mitigated, and the platform recalculates path probabilities in real time. Toggling T1078 as mitigated reduces attack probability from 69.1% to 34.2%, demonstrating the substantial risk reduction that credential hygiene initiatives can provide.

3.1.5 Addressing the Tracking Challenge: Temporal Analysis

Security posture is not static. Organizations conduct periodic assessments, remediate findings, deploy new systems, and inherit new vulnerabilities. Without historical tracking, each assessment exists in isolation, making it challenging to demonstrate progress, identify persistent problem areas, or hold remediation efforts accountable to measurable outcomes.

CRISP provides temporal analysis through trend visualization across assessment periods. The Site Dashboard displays three key metrics over time: total vulnerability count, aggregate severity score, and unique technique coverage. These parallel trend lines enable organizations to track whether remediation efforts are producing measurable improvement across multiple dimensions. A reduction in vulnerability count without a

corresponding drop in severity score might indicate that teams are resolving low-impact findings while high-impact issues persist.

In Figure 7, a site demonstrates consistent improvement across all three metrics, with 45.1% reductions in vulnerabilities, 45.0% in severity score, and 45.2% in technique coverage across five assessment periods.

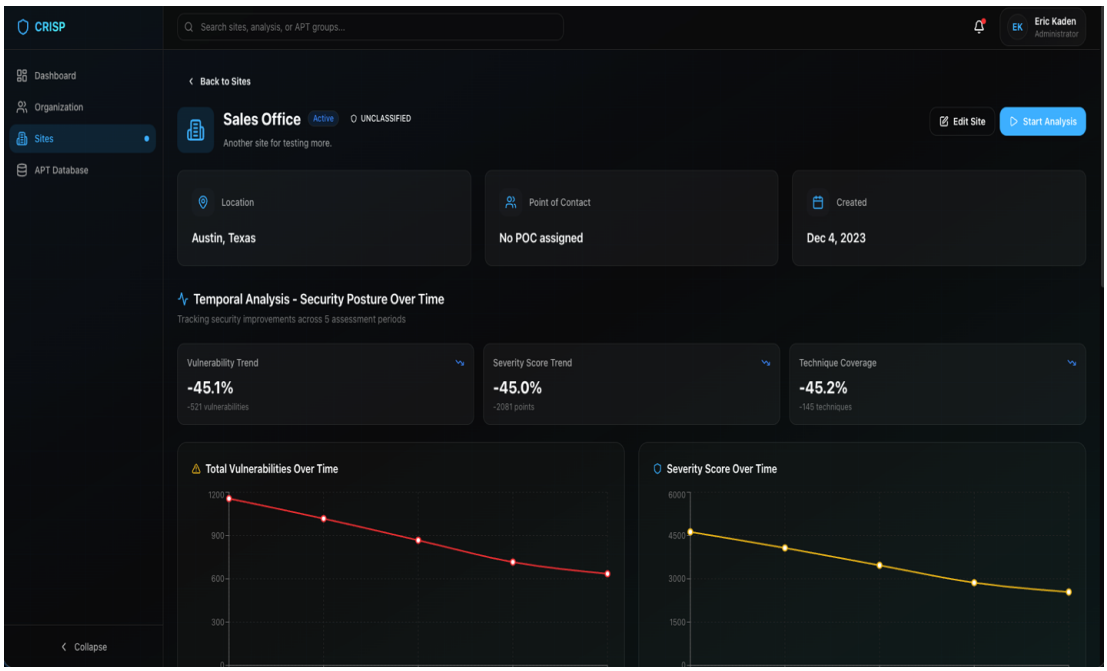


Figure 7: Site Dashboard with Temporal Trend Charts for Vulnerabilities, Severity Score, and Technique Coverage Across Multiple Assessment Periods

Beyond aggregate metrics, the platform tracks the prevalence of individual techniques over time. A comparison table displays the top techniques ranked by percentage of total findings for each assessment period. This view reveals which exposures persist despite remediation efforts and which the organization has successfully resolved. A technique that remains in the top five across multiple quarters may indicate a systemic architectural issue requiring deeper intervention rather than point fixes. The Analysis History panel provides a chronological view of all past assessments, including severity scores and completion status, enabling precise comparisons between assessment periods.

3.1.6 Addressing the Communication Challenge: LLM-Assisted Interpretation

Data visualizations convey information efficiently to trained analysts, but not every stakeholder possesses the background to interpret ATT&CK technique identifiers. Security teams frequently must translate technical findings into language accessible to executives, auditors, or operational staff. This translation process consumes time and introduces potential for miscommunication.

CRISP integrates a natural language chat assistant that receives full analysis context and answers queries in plain language, with response times under 500 milliseconds. Use cases span the expertise spectrum: an analyst might ask, "Explain T1078 Valid Accounts and why it matters," while a security lead might request, "Summarize the top three threats for an executive audience." This approach applies principles of retrieval-augmented generation (Lewis et al., 2020), grounding the model's responses in organizational data rather than relying on general-purpose pre-trained knowledge.

3.2 Additional Platform Capabilities

Beyond the core analysis pipeline, CRISP provides supporting capabilities for enterprise deployment. The built-in APT database described in Section 2.3 stores each group's identifier, known aliases, attributed country, documented techniques, and target sectors. The database supports one-click updates from MITRE's public repositories.

CRISP implements a hierarchical data model in which organizations contain sites, and sites contain analysis runs. The site creation interface captures metadata, including name, geographic location with autocomplete, time zone, classification level, and point of contact. Each analysis run is timestamped and permanently stored, creating an auditable record of the assessment. Export capabilities support integration with external workflows through Navigator JSON, CSV reports, and APT Overlap summaries.

3.3 Multi-Persona Use Case Walkthrough

To demonstrate how CRISP serves diverse stakeholders, the following walkthrough traces a realistic scenario through three organizational perspectives.

3.3.1 Scenario Setup

A quarterly STIG assessment has just concluded across a distributed enterprise with twelve sites. The assessment generated over 100,000 findings across multiple technology areas. Three stakeholders need different insights from this data: the CISO preparing for a board briefing, the SOC Lead allocating remediation resources, and the security analyst responsible for detailed technical analysis.

3.3.2 CISO Perspective

The CISO opens CRISP to the Organization Dashboard. Within seconds, she sees 12 sites under management, 3 active analyses, an aggregate severity score of 465 (down 23 points from last month), and 8 APT groups with significant technique overlap. The trend indicators confirm that organizational posture is improving. She switches to the Geographic Map View and identifies two East Coast sites with red markers indicating elevated risk, suggesting a regional issue worth discussing with the regional security director.

For the board briefing, she asks the AI Assistant: “Summarize our top three threat actors and what they mean for our risk posture.” The assistant returns a plain-language summary identifying APT29, APT28, and Lazarus Group as the highest-overlap adversaries. The total time required to extract executive-level intelligence from 100,000+ findings is under five minutes.

3.3.3 SOC Lead Perspective

The SOC Lead needs to prioritize remediation efforts. He navigates to the highest-severity site and opens the Attack Path Simulator. The most probable path shows a 69.1% likelihood chain from Valid Accounts through Command and Scripting Interpreter to Scheduled Task/Job. He toggles T1078 as mitigated and watches the attack probability drop to 34.2%, justifying the prioritization of credential hygiene initiatives.

He reviews the APT Threat Ranking and finds APT29 with 47 matching techniques, at 19.4% overlap. From there, he exports the APT Overlap CSV for his remediation team. In the temporal analysis, he notes that T1078 has remained in the top three for four consecutive quarters, indicating a systemic issue requiring architectural

intervention. The total time is fifteen minutes to develop a prioritized, threat-informed remediation plan.

3.3.4 Security Analyst Perspective

She opens the latest analysis run and reviews the Analysis Overview: 111 vulnerabilities, severity score 429, 242 unique ATT&CK techniques mapped. After exporting the Navigator JSON, she imports it into her team's standalone ATT&CK Navigator instance for comparative analysis. The embedded Navigator view reveals that Defense Evasion, with 43 techniques, has the highest concentration.

For documentation, she exports a CSV Report containing complete technique mappings, including finding counts, severity weights, and source STIG identifiers. The CSV report feeds directly into her team's remediation tracking spreadsheet. When her manager asks about a specific technique, she queries the AI Assistant rather than searching external documentation. The total time required to produce comprehensive technical artifacts is 20 minutes.

3.3.5 Value Demonstration

Three stakeholders extracted three distinct types of value from the same underlying data. The CISO obtained strategic intelligence for executive communication. The SOC Lead developed a prioritized remediation plan informed by adversary behavior and attack path analysis. The Security Analyst generated technical documentation integrated with existing workflows. None required manual correlation of STIG findings to threat frameworks. All drew from a single authoritative source, updated in minutes rather than days.

This multi-persona utility demonstrates that CRISP serves the full spectrum of organizational cybersecurity needs, from boardroom to operations center, without requiring separate tools or redundant analysis.

3.4 Qualitative Assessment

The following assessment evaluates CRISP against each criterion based on the capabilities and outputs demonstrated above. This evaluation reflects the author's

analysis of system outputs rather than independent user testing; Section 5.5 discusses this limitation and proposes empirical validation as future work.

3.4.1 Clarity

Clarity measures whether visualizations and outputs are intuitive and easy to understand. CRISP achieves clarity through deliberate design choices at multiple levels. At the executive tier, the Organization Dashboard presents KPIs with trend indicators requiring no specialized knowledge. Spatial intuition drives the Geographic Map View, while the ATT&CK Navigator uses the standard matrix layout familiar to security professionals worldwide. For operational planning, the Attack Path Simulator renders abstract technique chains as visual flowcharts with clear directional progression. Natural language translation rounds out the approach, with the AI Assistant converting technical findings into plain language on demand.

3.4.2 Actionability

Actionability measures whether outputs drive specific decisions. CRISP produces actionable outputs at every level. The APT Threat Ranking directly answers the question "which adversaries should we worry about?" with a prioritized list for threat-hunting efforts. The Attack Path Simulator answers "what should we fix first?" by quantifying how remediations reduce attack probability. Temporal analysis answers the question "are we improving?" with trend data, holding remediation programs accountable. Export capabilities extend actionability beyond the platform through Navigator JSON, CSV reports, and APT Overlap exports that flow into organizational processes.

3.4.3 Communicative Value

Communicative value measures whether stakeholders can share findings effectively across organizational levels. CRISP addresses this through multi-format outputs serving different audiences. The same analysis produces executive dashboards, threat rankings for security operations, technique heatmaps for analysts, and natural language summaries for non-technical stakeholders. A CISO can brief the board using the Geographic Map View, then share the same analysis with the SOC Lead, who extracts different insights from the Attack Path Simulator. The AI Assistant bridges

communication gaps; a request like “summarize for an executive audience” produces output ready for cross-functional distribution.

Taken together, these criteria confirm that CRISP produces outputs that are understandable, useful, and shareable: the essential qualities of operational security intelligence.

4. Recommendations and Implications

4.1 Recommendations for Practice

Organizations conducting regular STIG assessments should integrate threat-informed analysis into their compliance workflows. Compliance data already exists; the marginal effort to transform it into threat intelligence is minimal compared to the strategic value gained. Organizations should move beyond severity-based prioritization toward adversary-aligned prioritization, accounting for which threat actors are most likely to target their sector. Investment in visualization capabilities pays dividends in executive communication and cross-functional alignment.

Vendors building vulnerability management, compliance, and threat intelligence platforms should consider tighter integration between these traditionally separate domains. The mapping infrastructure connecting STIG findings to NIST controls to ATT&CK techniques is not proprietary; MITRE publishes these relationships openly. Vendors that incorporate this pipeline can differentiate by delivering threat-contextualized outputs rather than competing solely on scanning speed or finding volume.

Analysts spending significant time on manual correlation should advocate for automation. The techniques demonstrated in CRISP are reproducible; the underlying data sources are publicly available. Analysts can redirect time saved on data processing toward interpretation, threat hunting, and proactive defense. Academic researchers should consider the compliance-to-threat translation problem as a testbed for applied AI in cybersecurity, exploring machine learning to improve mapping accuracy and natural language processing to integrate unstructured threat intelligence.

4.2 Future Research and Extensibility

Near-term enhancements could expand data ingestion to support Security Content Automation Protocol (SCAP) results, CKL files from STIG Viewer, and commercial scanner exports. Integration with vulnerability databases, such as the National Vulnerability Database and CISA's Known Exploited Vulnerabilities catalog, could enrich analysis by providing data on the likelihood of exploitation. Prior research has demonstrated that incorporating exploit probability into remediation decisions yields measurably better prioritization outcomes (Jacobs et al., 2021).

Medium-term research could apply machine learning to improve mapping accuracy and risk prediction. The current pipeline uses static reference files; a learned model would account for contextual factors such as network architecture, asset criticality, and historical exploitation patterns. Anomaly detection techniques such as Isolation Forest (Liu et al., 2008) offer promise for identifying unusual patterns warranting investigation. Deep learning approaches to log analysis (Du et al., 2017; Guo et al., 2021) suggest similar techniques may enhance compliance data interpretation.

The long-term vision extends beyond periodic assessments to continuous security posture management through real-time integration with SIEM platforms, endpoint detection systems, and network monitoring tools. Automated remediation recommendation, where CRISP suggests specific configuration changes based on technique mappings, represents another frontier. Several open problems warrant attention: mapping validation against real attack data, weighting techniques by exploitation frequency, and empirically correlating compliance posture with breach risk.

4.3 Broader Implications

The traditional view treats compliance and security as related but distinct concerns. This dichotomy is false, as researchers have increasingly recognized (Kwon et al., 2020). Compliance data, correctly interpreted, constitutes threat intelligence. Every STIG finding represents a potential adversary capability. Organizations that recognize compliance data as raw intelligence can extract strategic value from activities they already perform for regulatory purposes.

Sophisticated threat intelligence has historically been accessible primarily to well-resourced organizations, with adoption barriers that researchers have documented across government, academia, and industry (Al-Sada et al., 2024). CRISP demonstrates that automated pipelines can deliver adversary-driven analysis to organizations lacking specialized expertise. The underlying data sources are public; the barrier was integration, not access. Platforms that automate this integration democratize threat intelligence, enabling smaller organizations to benefit from adversary-aligned defense strategies previously available only to large enterprises and government agencies.

CRISP represents one instance of a broader trend toward automated security analysis leveraging AI and machine learning, a direction that recent research in vulnerability remediation has validated (Zhang et al., 2020). As large language models mature, their integration into security workflows will deepen. The future security operations center may rely less on analysts performing manual lookups and more on intelligent systems surfacing relevant insights on demand. Human expertise remains essential for judgment, context, and decision-making, but the mechanical work of data transformation and correlation increasingly belongs to machines.

5. Conclusion

5.1 Return to the Problem

The problem that sparked this research was not technical complexity but operational frustration. A skilled analyst with access to comprehensive compliance data still could not answer the question leadership most needed answered: given what we know about our configuration weaknesses, which adversaries should concern us most, and what should we fix first? That gap between compliance output and threat insight no longer needs to exist.

5.2 Contributions Summarized

This research makes four contributions to the field. First, it demonstrates technical feasibility: automated transformation of STIG compliance data into ATT&CK-aligned threat intelligence is achievable at enterprise scale, processing over 300,000 findings in under five minutes with a 99.94% data reduction ratio. Second, it provides a reference

implementation that documents the architecture, data models, and processing pipeline for organizations and vendors seeking similar capabilities. Third, it validates multi-persona utility, showing that a single platform can serve executives, security operations leads, and analysts without requiring separate tools or manual translation. Fourth, it establishes a conceptual foundation by articulating the compliance-as-intelligence paradigm, reframing mandatory assessment activities as threat intelligence opportunities.

This paper argued that an integrated platform automating the end-to-end transformation of STIG compliance data into threat-informed security posture could dramatically reduce analysis time while producing actionable, executive-ready intelligence. The evidence supports this claim. Analysis time collapsed from days to minutes. Outputs evolved from compliance metrics to threat intelligence. Prioritization shifted from severity categories to adversary alignment.

5.3 Impact Across the Enterprise

The significance of multi-persona utility extends beyond individual productivity gains. When executives, operations leads, and analysts draw from the same authoritative data source, organizational alignment improves. A CISO's strategic priorities connect directly to the SOC Lead's remediation plan, which in turn connects to the analyst's technical artifacts. This shared analytical foundation eliminates the translation gaps that typically fragment security communication across organizational levels.

5.4 Paradigm Shift

Beyond operational efficiency, CRISP embodies a reconceptualization of compliance activities. The traditional view treats compliance as a regulatory burden and security operations as a separate concern. This separation is artificial. Every STIG finding documents a configuration state that enables or constrains adversary behavior. Every remediated misconfiguration removes a technique from an attacker's playbook. Organizations that recognize compliance data as intelligence raw material unlock strategic value from activities they already perform.

5.5 Limitations and Future Directions

This research has limitations that warrant acknowledgment. The evaluation demonstrated feasibility through qualitative assessment rather than controlled experimental comparison; future work should measure analyst performance with and without the platform to quantify productivity gains. The mapping pipeline depends on reference data maintained by external organizations; changes to NIST or MITRE frameworks require corresponding updates. The LLM integration reflects current model capabilities that will evolve as language models improve. Finally, the current implementation focuses on STIG data; expanding to additional compliance frameworks such as CIS Benchmarks, PCI-DSS, and HIPAA controls remains future work.

5.6 Closing Statement

What began as a conversation about spreadsheet fatigue became a platform that transforms how organizations understand their security posture. The analyst who once faced twelve files and three days of manual processing can now upload those files and receive threat-aligned intelligence before finishing a cup of coffee. More importantly, the commanders who once received reports counting misconfigurations can now receive briefings identifying which adversaries those misconfigurations enable.

We are no longer counting findings. We are stopping adversaries.

References

Al-Sada, B., Sadighian, A., & Oligeri, G. (2024). MITRE ATT&CK: State of the art and way forward. ACM Computing Surveys, 57(1), Article 12, 1–37. https://doi.org/10.1145/3687300

Defense Information Systems Agency. (2025). Security Technical Implementation Guides (STIGs). DoD Cyber Exchange. https://public.cyber.mil/stigs/

Du, M., Li, F., Zheng, G., & Srikumar, V. (2017). DeepLog: Anomaly detection and diagnosis from system logs through deep learning. Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS), 1285–1298. https://doi.org/10.1145/3133956.3134015

Guo, H., Yuan, S., & Wu, X. (2021). LogBERT: Log anomaly detection via BERT. arXiv preprint arXiv:2103.04475. https://arxiv.org/abs/2103.04475

Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. MIS Quarterly, 28(1), 75-105. https://doi.org/10.2307/25148625

Jacobs, J., Romanosky, S., Adjerid, I., & Baker, W. (2021). Improving vulnerability remediation through better exploit prediction. Proceedings of the 30th USENIX Security Symposium, 2117-2134. https://www.usenix.org/conference/usenixsecurity21/presentation/jacobs

Jiang, Y., Meng, Q., Shang, F., Oo, N., Minh, L. T. H., Lim, H. W., & Sikdar, B. (2025). MITRE ATT&CK applications in cybersecurity and the way forward. arXiv preprint arXiv:2502.10825. https://arxiv.org/abs/2502.10825

Kwon, R., Ashley, T., Castleberry, J., McKenzie, P., & Gourisetti, S. N. G. (2020). Cyber threat dictionary using MITRE ATT&CK matrix and NIST Cybersecurity Framework mapping. In 2020 Resilience Week (RWS) (pp. 106–112). IEEE. https://doi.org/10.1109/RWS50334.2020.9241271

Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Kuttler, H., Lewis, M., Yih, W., Rocktaschel, T., Riedel, S., & Kiela, D. (2020). Retrieval-augmented generation for knowledge-intensive NLP tasks. Advances in Neural Information Processing Systems, 33, 9459-9474. https://arxiv.org/abs/2005.11401

Liu, F. T., Ting, K. M., & Zhou, Z. H. (2008). Isolation forest. Proceedings of the 2008 IEEE International Conference on Data Mining (ICDM), 413–422. https://doi.org/10.1109/ICDM.2008.17

MITRE Corporation. (2022). Mapping NIST SP 800-53 Rev. 5 to MITRE ATT&CK. Center for Threat-Informed Defense. https://center-for-threat-informed-defense.github.io/mappings-explorer/

Zhang, F., Huff, P., McClanahan, K., & Li, Q. (2020). A machine learning-based approach for automated vulnerability remediation analysis. 2020 IEEE Conference on Communications and Network Security (CNS), 1–9. https://doi.org/10.1109/CNS48642.2020.9162309